

the 'privileged account' credentials that grant certain users administrator/power levels of access.

Platform challenges: The hardware must be kept up to date to avoid security breaches. Refreshing hardware in a timely manner with minimal impact is a key challenge, particularly since the new/updated hardware version may come with new security challenges as well.

Operational challenges: Continuous monitoring across the platform becomes harder with the increase in the number of resources and size of logs. This makes security monitoring complex and expensive. Security analytics from countless logs becomes a challenging task, even though we may have hundreds of tools, as the attackers find new approaches and methods every now and then.

Endpoint security: The importance of endpoint security has increased as users are connecting from multiple devices like laptops, desktops, mobiles and PDAs (personal digital assistants). Each device connecting to the organisation's network creates a potential entry point for security threats. Hackers typically use vulnerable endpoints as entries into the organisation's network, to create a big impact.

Network security: There is a need to recognise and authorise each user and each device that connects with the organisation's network. Non-compliant endpoint devices have to be blocked or given only limited access. Proper firewall rules will save you from more attacks by creating a barrier between internal and outer networks.

Physical security: Physical security is the protection of personnel, hardware, software, networks and data from physical actions and events that could cause serious loss or damage to an enterprise, agency or institution. This includes protection from fire, floods, natural disasters, burglary, theft, vandalism and terrorism.

Communication encryption: This is very essential for securing data in transit to avoid sensitive data from being

intercepted. The value of encryption extends beyond safety, as many organisations are obligated to encrypt sensitive information, with penalties for the damages resulting from regulatory non-compliance.

Interface/API hacking: Interface hacking exposes resources to the world and makes them vulnerable to attackers. Often the attacker will try multiple spoofing methods to break API level security to get in, adding more challenges that need to be addressed. The major risk of APIs is that they often expose the underlying details of the application's implementation, along with insights into other internal objects. This is valuable data that arms hackers to penetrate even further.

Open source tools for IaaS security

Let us look at some popular open source tools that secure IaaS implementations.

Nmap

Nmap (Network Mapper) is a free and open source (licence) utility for network discovery and security auditing. Its NSE scripts can detect vulnerabilities, misconfiguration and security related information around network services. Nmap uses raw IP packets in novel ways to detect the available hosts on the network, the running services, the version (application), operating systems and their versions, the type of packet filters/firewalls in use, etc.

As Nmap has grown in functionality over the years, it has become an important port scanner and this remains its core function. The simple command *Nmap <target>* scans 1,000 TCP ports on the host *<target>*. While many port scanners have traditionally lumped all ports into the open or closed states, Nmap is much more granular. It divides ports into six states: open, closed, filtered, unfiltered, open|filtered or closed|filtered.

Listed below are a few examples of how Nmap can be used for daily routine tasks.

To scan all reserved TCP ports on the machine *server1.abc.org* in verbose mode, use the following code:

```
#nmap -v server1.abc.org
```

To TCP scan the 198.116 Class B address space and test whether the systems run SSH, DNS, POP3, or IMAP on their standard ports, or anything on port 4564, use the code given below:

```
#nmap -sV -p 22,53,110,143,4564 198.116.0-255.1-127
```

Nmap will do random scans of 100 Web servers (port 80) by using the command shown below:

```
#nmap -v -iR 100 -Pn -p 80
```

To scan 4096 IPs for any Web servers (without pinging them) and save the output in greppable and XML formats, use the following code:

```
#nmap -Pn -p80 -oX logs/pb-port80scan.xml -oG logs/pb-port80scan.gnmap 216.163.128.20/20
```

Snort

Snort is based on libcap (library packet capture) and is used for network intrusion detection and prevention, and in traffic analysis and packet logging on IP networks. Through protocol analysis, content searching and various pre-processors, Snort detects thousands of worms, vulnerability exploit attempts, port scans and other suspicious behaviour. Snort uses a flexible rule based language to describe traffic that it should collect or pass, and a modular detection engine. It can monitor the network traffic in real-time, scrutinising each packet closely to detect dangerous payloads or suspicious anomalies.

Snort supports the Centos, Debian, Fedora, FreeBSD, RHEL and Ubuntu platforms. To create a custom configuration, you need to update the following configurations, which can be